MODUL PEMBELAJARAN

Pertemuan 5: Information Gathering dan Reconnaissance

Mata Kuliah Penetration Testing (KSI251522) | Semester 5

Program Studi Sarjana Terapan Keamanan Sistem Informasi

Politeknik Negeri Bengkalis

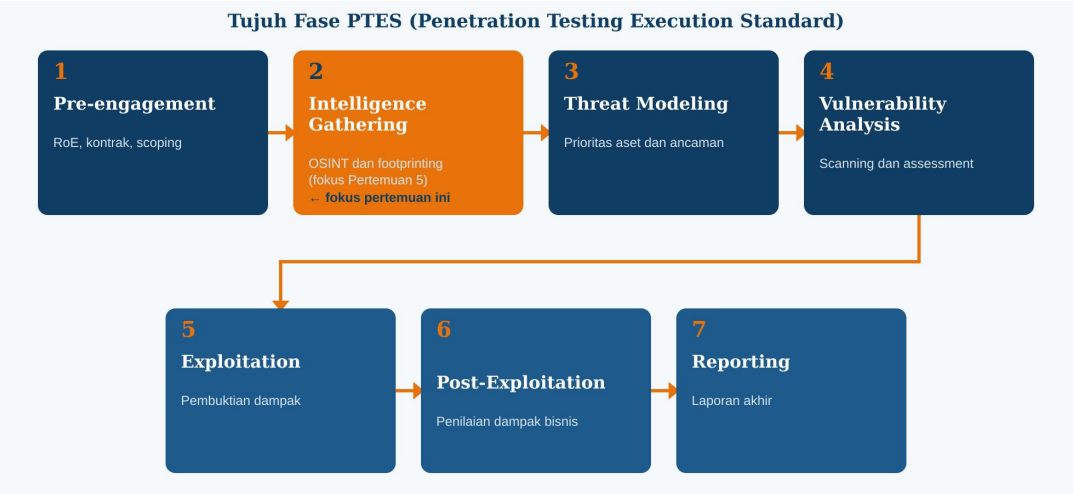
Dosen Pengampu: Nurmi Hidayasari

Sub-CPMK	02.1 Mampu menyiapkan tujuan, ruang lingkup, prosedur, alat, dan bukti yang diperlukan untuk identifikasi awal permukaan serangan.
Sifat pengujian	Individu. Setiap mahasiswa menggunakan website proyek yang telah dipublikasikan dan tercantum dalam RoE.
Fokus PTES	Fase 2: Intelligence Gathering.
Output utama	Reconnaissance Log, Evidence, Attack Surface Map, dan Reconnaissance Summary.
Batas utama	Tidak melakukan exploitation, brute force, DoS, credential attack, perubahan data, atau aktivitas di luar RoE.

Capaian Pembelajaran

- Memilih teknik dan tools reconnaissance sesuai tujuan, ruang lingkup, dan Rules of Engagement (RoE).
- Mengidentifikasi domain, subdomain, endpoint, teknologi, dan aset digital yang relevan.
- Membedakan discovery, validation, attack surface identification, dan vulnerability identification.
- Mendokumentasikan temuan dengan evidence yang dapat ditelusuri dan diverifikasi ulang.
- Menyusun attack surface map sebagai input untuk Threat Modeling dan Vulnerability Analysis pada pertemuan berikutnya.
- Menjaga seluruh aktivitas tetap berada dalam target dan batasan RoE.

A. Basic Information Gathering



Fase 1 (Pre-engagement) sudah selesai di Pertemuan 2 dalam bentuk RoE. Fase 3–7 akan dipelajari mulai Pertemuan 6 dan seterusnya. Fokus kita hari ini murni pada Fase 2.

Information Gathering merupakan tahapan awal dalam proses Penetration Testing yang bertujuan untuk mengumpulkan informasi-informasi penting terhadap target.

Untuk Apa informasi tersebut?

Information gathering juga sering disebut dengan Reconnaissance. Sama halnya pada saat berperang, tidak mungkin datang langsung serang, diperlukan kelompok-kelompok dalam perang yang bertugas untuk mengumpulkan informasi-informasi penting dari musuh yang nantinya akan dijadikan sebagai taktik serangan. Untuk penjelasan lebih lanjut silahkan tonton video pada di sini.

Dalam *information gathering*, terdapat dua teknik yang dapat kita lakukan, yaitu *passive* dan *active*. Pahami perbedaan keduanya.

90% kegiatan pentest itu berada di information gathering semakin banyak informasi yang kita dapatkan, maka akan semakin banyak pula kemungkinan kita bisa menemukan celah keamanan pada sebuah website. Tiap orang punya cara berbeda yang dapat membedakan informasi yang didapat. Dalam modul ini kita akan membahas teknik-teknik secara umum, selanjutnya rekan-rekan mahasiswa dapat mengeksplor dan mencoba teknik lain.

Berikut *tools* dan contoh penggunaannya yang dapat Anda gunakan untuk mengumpulkan informasi sesuai dengan target masing-masing.

Sebelum lanjut, pastikan website target Anda sudah ada dan dapat diakses!!!

Jangan lupa dokumentasi setiap langkah yang dikerjakan!

Aturan praktikum: Jika reconnaissance menemukan subdomain, IP, domain, akun, atau sistem lain yang berada di luar scope, catat sebagai observasi dan hentikan pengumpulan informasi lebih lanjut terhadap aset tersebut.

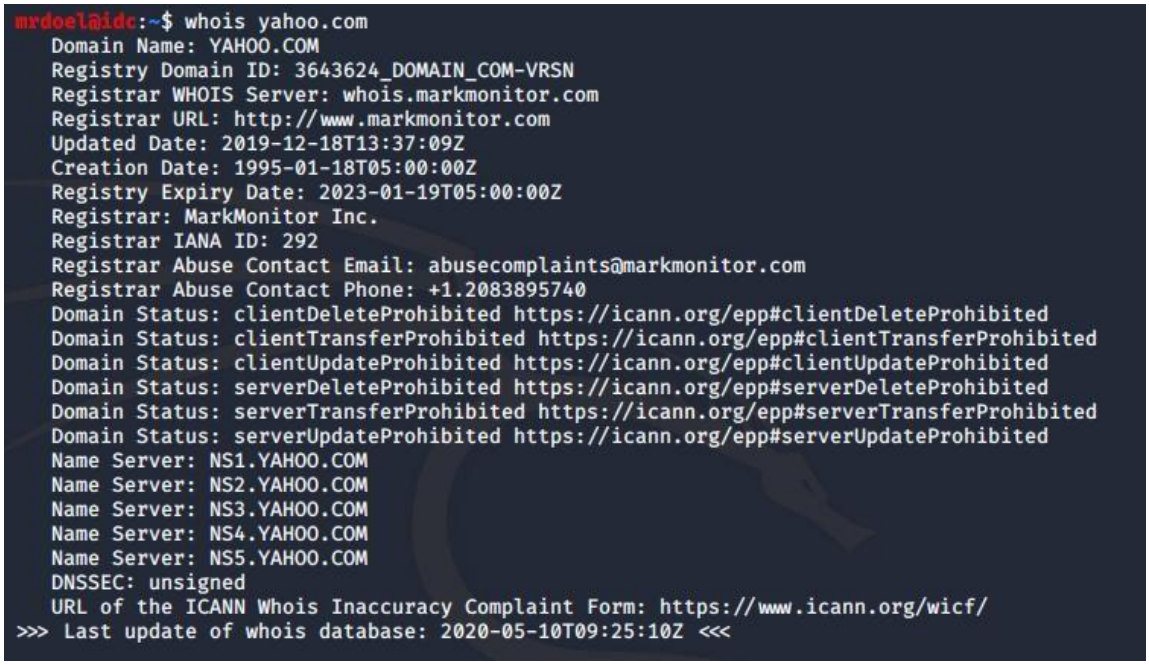
B. WHOIS

Pada teknik pertama ini akan kita mulai dengan WHOIS. WHOIS merupakan sebuah metode yang akan menampilkan informasi tentang nama domain atau alamat IP. Informasi yang ditampilkan bisa berupa nama pemilik domain, masa berlaku domain, alamat, *email*, telpon, alamat DNS dan lain-lain. WHOIS tersedia dalam berbagai macam

penggunaan,dapat dijalankan dengan meggunakan *tool* maupun secara online (*via website*). Pada Kali Linux, WHOIS dapat kita jalankan dengan perintah:

whois <nama domain>

Jika domain tersedia, maka akan tampil informasi lengkap dari domain contohnya gambar berikut.



Terdapa informasi kapan domain tersebut dibuat, kapan expired, nama server yang digunakan dan informasi lain. Informasi ini bisa sangat berguna dalam tahap pengumpulan informasi, namun informasi dari beberapa domain biasanya tidak dapat ditampilkan karena menggunakan layanan pihak ketiga untuk menyembunyikan informasi domain.

C. Subdomain Enumeration

Kita sudah membahas sebelumnya bahwa semakin banyak informasi yang bisa kita kumpulkan maka kemungkinan untuk menemukan celah keamanan juga akan semakin besar. Salah satu caranya adalah dengan mengumpulkan website-website lainnya yang dimiliki oleh target seperti Subdomain. Sudah hal umum bahwa perusahan-perusahaan besar seperti yahoo, facebook, twitter dan lain-lain menggunakan subdomain misalnya business.target.com, members.target.com atau juga mail.target.com. Inilah yang disebut dengan subdomain enumeration, yaitu proses mengumpulkan subdomain yang dimiliki dari domain utama.

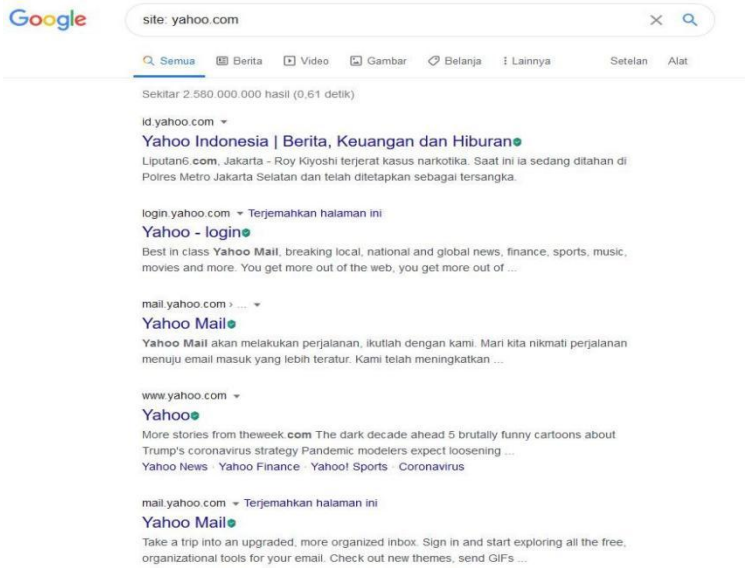
Biasanya visitor website lebih memilih untuk mengunjungi website utama contohnya yahoo.com sedangkan subdomainnya jarang dikunjungi dan juga biasanya jarang diperhatikan oleh developer sehingga banyak dari subdomain ini tidak update. Disinilah peluang bagi pentester untuk menemukan celah keamanan. Hal ini bisa kita lihat pada laporan-laporan bug bounty di hackerone, dimana celah keamanan paling banyak terdapat pada subdomain. Bugnya pun beragam seperti informasi sensitif, bypass login,third party website yang tidak di-*update* serta bug-bug unik lainnya.

Biasanya kalau lagi mencari bug, lebih sering yang ditarget pertama kali adalah subdomainnya. Kadang juga domain utama. Dalam hal ini, kita akan fokus untuk mencari subdomain dengan metode passive information gathering. Artinya kita mencari subdomain tanpa melakukan interaksi langsung dengan website target semua informasi kita dapatkan dari *public source* seperti *search engine*.

- **Subdomain Enumeration Menggunakan Google**

Cara pertama yang bisa kita lakukan untuk mencari subdomain adalah dengan menggunakan pencarian di Google. Simplenya kita bisa menggunakan google dork

```
site: target.com
```

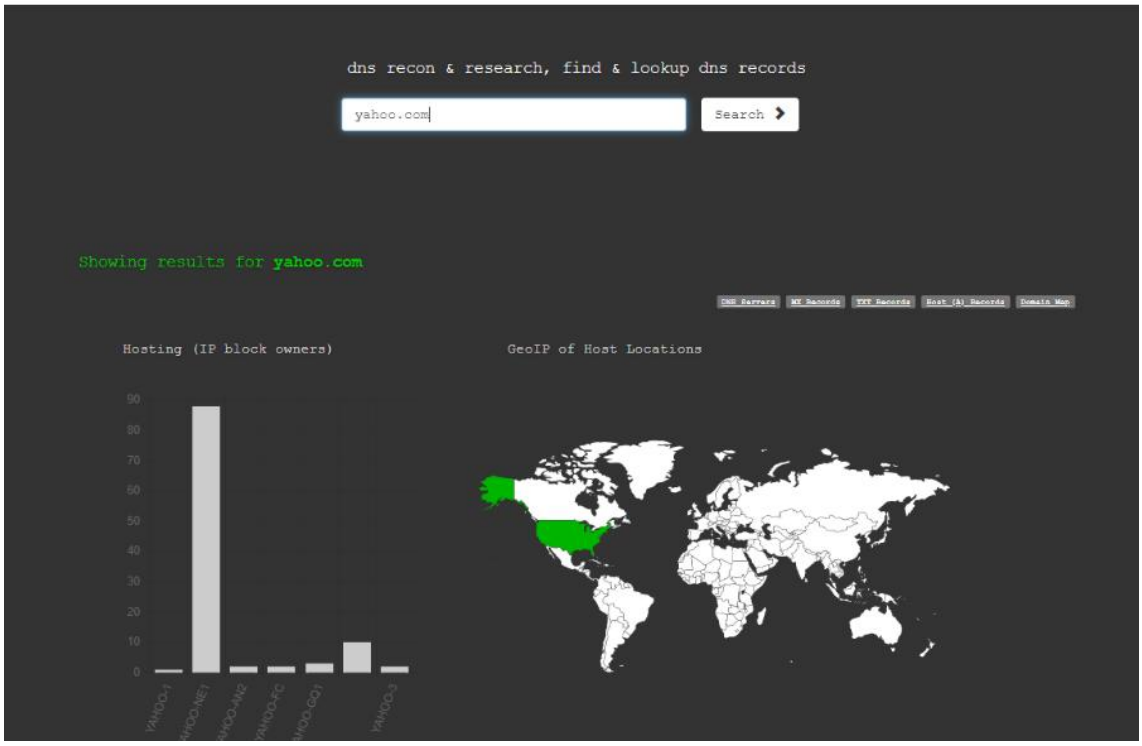


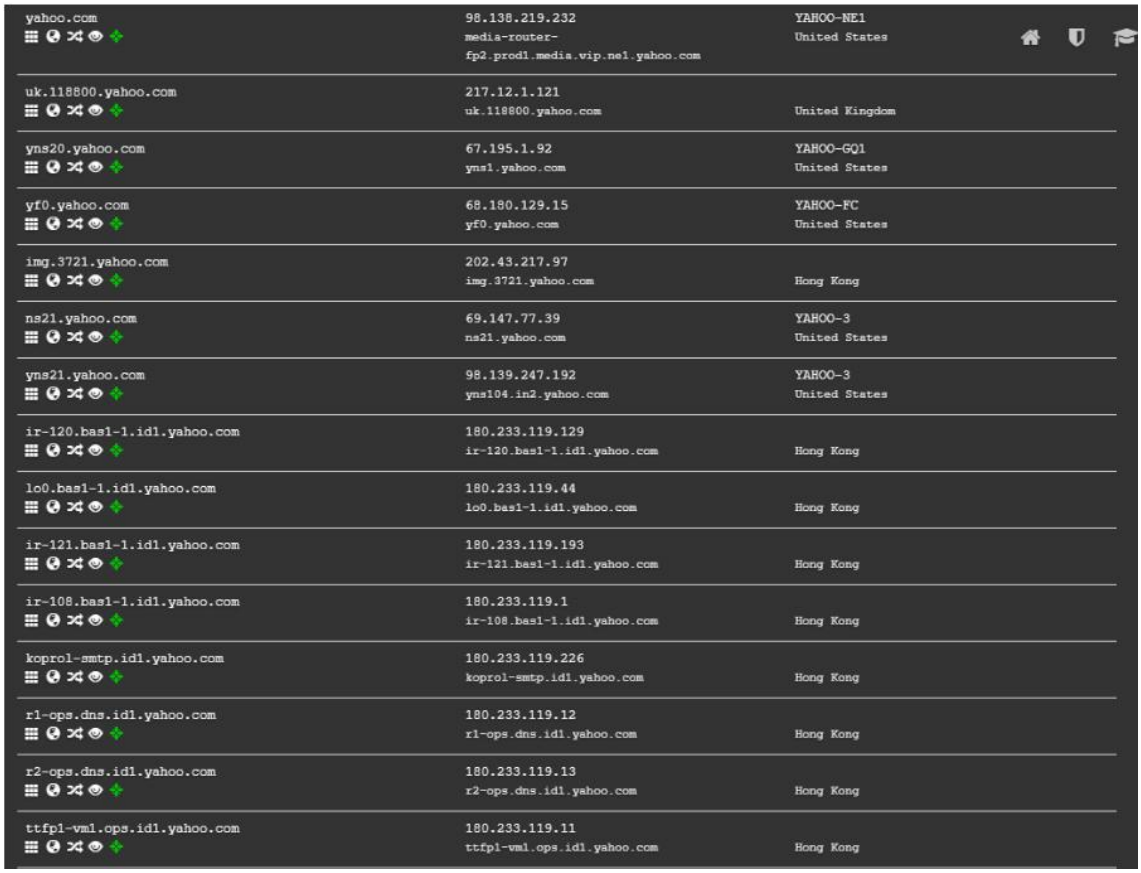
Pada gambar di atas, terlihat beberapa subdomain yang ditemukan. Akan muncul masalah ketika subdomainnya sangat banyak, seperti pada gambar terdapat 2,5 miliar hasil pencarian, sangat memakan waktu jika kita harus mencatat satu persatu. Diperlukan sebuah tool yang bisa melakukan pencarian subdomain ini secara otomatis

dan hasilnya bisa tampil dalam format list. Tool inilah yang akan kita pelajari pada modul selanjutnya

D. Dnsdumpter

Cara lainnya yang dapat kita gunakan untuk mencari subdomain adalah dengan menggunakan DNSdumpster. Caranya adalah akses URL https://dnsdumpster.com kemudian masukkan domain pada form dan klik search. Maka akan tampil subdomain yang didapatkan dari berbagai sumber.





yahoo.com	98.138.219.232 media-router-fp2.prod1.media.vip.ne1.yahoo.com	YAHOO-NE1 United States
uk.118800.yahoo.com	217.12.1.121 uk.118800.yahoo.com	United Kingdom
yns20.yahoo.com	67.195.1.92 yns1.yahoo.com	YAHOO-GQ1 United States
yf0.yahoo.com	68.180.129.15 yf0.yahoo.com	YAHOO-FC United States
img.3721.yahoo.com	202.43.217.97 img.3721.yahoo.com	Hong Kong
ns21.yahoo.com	69.147.77.39 ns21.yahoo.com	YAHOO-3 United States
yns21.yahoo.com	98.139.247.192 yns104.in2.yahoo.com	YAHOO-3 United States
ir-120.bas1-1.id1.yahoo.com	180.233.119.129 ir-120.bas1-1.id1.yahoo.com	Hong Kong
lo0.bas1-1.id1.yahoo.com	180.233.119.44 lo0.bas1-1.id1.yahoo.com	Hong Kong
ir-121.bas1-1.id1.yahoo.com	180.233.119.193 ir-121.bas1-1.id1.yahoo.com	Hong Kong
ir-108.bas1-1.id1.yahoo.com	180.233.119.1 ir-108.bas1-1.id1.yahoo.com	Hong Kong
koprol-smtp.id1.yahoo.com	180.233.119.226 koprol-smtp.id1.yahoo.com	Hong Kong
r1-ops.dns.id1.yahoo.com	180.233.119.12 r1-ops.dns.id1.yahoo.com	Hong Kong
r2-ops.dns.id1.yahoo.com	180.233.119.13 r2-ops.dns.id1.yahoo.com	Hong Kong
ttfp1-vm1.ops.id1.yahoo.com	180.233.119.11 ttfp1-vm1.ops.id1.yahoo.com	Hong Kong

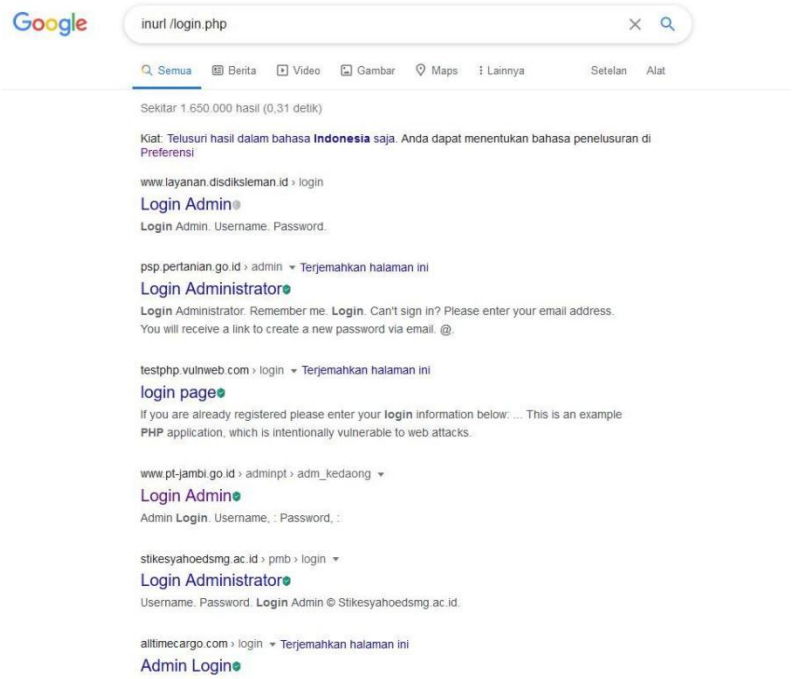
Namun terdapat pembatasan, DNSdumpster hanya mengizinkan kita untuk menerima 100 subdomain saja. Jika ingin lebih dari 100, maka kita harus bayar.



E. Google Hacking

Beberapa dari anda mungkin sudah mengenal atau pernah mendengan tentang Google Dork, karena Google Dork inilah banyak para *hacker* bisa mendapatkan target untuk melakukan aksi *hacking* pada website.

Google Dork merupakan filter yang dapat anda tambahkan pada saat pencarian dengan menggunakan Google agar apa yang ingin anda cari lebih akurat dan efisien.Berikut adalah cara untuk menggunakan Google Dork. Misalnya anda ingin mencari halaman *login* pada sebuah website, maka Dork nya adalah:



inurl:/login.php

Terlihat pada Gambar diatas, hasilnya akan muncul berbagai macam URL yang berhubungan dengan admin. Untuk pencarian yang lebih spesifik, sebagai contoh anda ingin mencari halaman admin pada website tertentu formatnya adalah sebagai berikut:

inurl:/administrator site:example.com

Berikut adalah beberapa format yang dapat anda gunakan pada Google Dork:

- **site**

  Dork ini akan menampilkan informasi website yang lebih spesifik. Sebagai contoh jika kita ingin menampilkan informasi-informasi pada website http://indonesiancoder.com maka dorknya adalah: **site:target.com**

  Kita juga dapat mencari untuk domain tertentu, misalnya ingin mencari semua website yang berhubungan dengan domain .co.id, maka dorknya adalah: **site:.co.id**

- **intitle**

  Dork ini akan menampilkan halaman dengan judul tertentu pada suatu website. Misalnya kita ingin mencari artikel yang memiliki judul "*Network*", maka dorknya adalah: i**ntitle:Network**

  Dalam penggunaan intitle, tidak boleh ada spasi setelah index karena fungsi dari intitle hanya untuk pencarian dengan satu istilah saja. Untuk menggunakan dua atau

lebih isitlah anda dapat menggunakan dork allintitle.

- **allintitle**

Dork allintitle hampir sama dengan intitle, perbedaanya dengan menggunakan allintitle, dapat menggunakan lebih dari satu istilah untuk mencari suatu judul halaman dari suatu website, tidak seperti intitle yang hanya dapat melakukan pencarian pada satu istilah. Contohnya **allinurl:Web Hacking** akan sama dengan **intitle:Web intitle:Hacking.**

Namun, terkadang antara allintitle dengan intitle tidak ada perbedaan karena sering menampilkan hasil yang sama dan sedikit sekali perbedaannya. Anda bisa menggunakan format manapun tergantung kebutuhan anda.

- **intitle**

Dork inurl akan menampilkan URL sesuai dengan format yang kita tentukan, misalnya kita ingin mencari URL yang mengandung format /upload maka dorknya adalah: **inurl:/upload**

- **related**

Dork related digunakan untuk mencari website yang mirip dengan website tertentu, misalnya anda ketikkan dork berikut: related:bing.com

Maka akan tampil website yang mirip seperti Bing contohnya *Google Search*, *Ask.com*, *AOL Search*, *Yahoo Search* dan lain-lain.

- **cache**

Dork cache digunakan untuk mencari cache pada website, dork ini berguna ketika ada website yang sudah down (tidak aktif) namun kita masih dapat mengakses data-data yang tersimpan oleh Google.

cache:example.com

- **intext**

Dork intext akan menampilkan semua website berisi teks yang kita inputkan pada dork ini. Misalnya kita ingin mencari website yang memiliki teks “Baju Unik” maka dorknya adalah : **intext:”Baju Unik”**

Macam-macam dork diatas dapat anda kombinasikan, contohnya anda ingin mencari halaman admin pada semua domain .co.id dimana halaman admin tersebut terdapat teks “Copyright 2012”, dorknya adalah sebagai berikut:

inurl:/admin site:.co.id intext:”Copyright 2012”

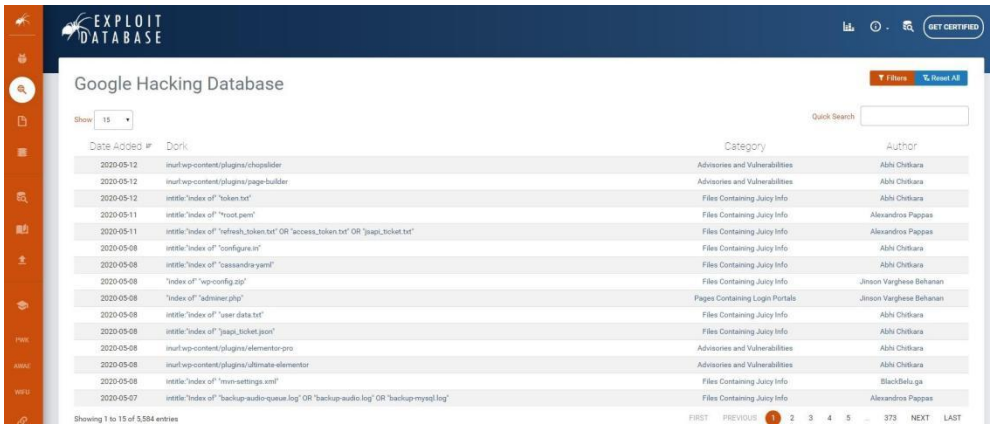
Anda bisa bereksperimen sesuka anda. Untuk mengetahui lebih lanjut tentang Google Dork, anda bisa membaca *e-book* yang ditulis oleh Johnny Long berjudul "*Google Hacking for Penetration Testers*", *e-book* ini dapat anda cari di internet dan dapat di-*download* secara gratis.

F. Google Hacking Database (GHDB)

Google Hacking Database (GHDB) dibuat oleh Johnny Long yang sebelumnya menulis *e-book tentang Google Hacking For Penetration Test*ers, Johnny banyak menulis *e-book* yang berhubungan dengan *Google Hacking*.

GHDB merupakan kumpulan *Google Dork* yang berhubungan dengan *hacking* seperti dork untuk mencari *username*, password, server yang memiliki bug, konfigurasi yang salah, *leaked file* dan lain-lain. Dengan adanya GHDB anda bisa belajar cara menggunakan *Google Dork* untuk keperluan anda dalam hacking dan juga anda dapat memodifikasi dork yang terdapat pada GHDB. Saat ini GHDB terintegrasi dan dapat diakses langsung via Exploit Database. Exploit database menyimpan ratusan exploit mulai dari Web Application, Dos, Shellcode dan lain-lain yang juga berfungsi sebagai referensi bagi anda yang ingin mencari celah keamanan pada suatu sistem.

URL
https://www.exploit-db.com/google-hacking-database/



G. Directory and File Enumeration

Secara umum, pengunjung website atau search engine tidak mengetahui direktori dan file apa saja yang terdapat pada website kecuali dikrektori dan file tersebut dipublikasikan dalam bentuk link pada halaman website.

Ketika misalnya developer website membuat sebuah fitur baru yang berada pada direktori **/baru** tidak ada seorangpun yang mengetahui kecuali pemilik website hingga direktori tersebut di publikasikan.

Dalam bug bounty ada istilah **Good Recons Wins!** Yang artinya recon yang paling baik akan menentukan pemenang yang bisa mendapatkan bounty (hadiah). Misalnya ada sebuah website yang mengadakan program bug bounty dan kemudian yang mengikuti program tersebut ada 1000 orang, maka yang menentukan siapa pemenangnya adalah yang terbaik proses mengumpulkan informasi.

Salah satu cara yang bisa kita lakukan untuk memperbesar cakupan target kita adalah dengan melakukan Directory and File Enumeration. Enumeration disini maksudnya kita mencari "resource" yang tersembunyi pada website, contohnya seperti fitur baru pada website, file backup yang mungkin lupa dihapus, directory yang berisi file sensitif, menemukan halaman login administrator dan lain-lain.

Terdapat dua cara yang dapat kita lakukan untuk melakukan **enumeration**, yaitu

- Pure Brute-Force
- Dictionary Attacks

1. Pure Brute Force

Pure Brute Force adalah teknik enumeration dimana kita mencoba setiap kombinasi karakter. Namun cara ini memakan waktu yang sangat lama. Sebagai contoh saja, untuk menemukan direktori dengan nama "**home**", kita membutuhkan ribuan percobaan. Contohnya sebagai berikut.

Kombinasi	**Direktori**
h	home
ha	
hb	
hc	
hd	
hom	
homa	

Cara ini sangat memakan banyak waktu. Terdapat cara yang lumayan efektif yaitu menggunakan dictionary attack.

2. Dictionary Attack

Dictionary attack adalah teknik enumeration dimana kita mencari nama direktori dan file berdasarkan daftar kata-kata yang telah kita tentukan, kumpulan kata-kata ini disebut sebagai **wordlists**.Untuk membuat wordlists, kita harus melihat secara umum pada website itu terdapat direktori dan file apa. Contohnya pada website yang menggunakan wordpress dimana terdapat direktori :

- Wp-admin
- Wp-content
- Wp-includes
- Dan lain-lain

Kita juga bisa mencari file dengan kombinasi wordlist dan ekstensi, contohnya :

- Backup.bak
- Info.old
- Admin.txt
- Dan lain-lain

Dictionary attack lebih efisien daripada pure brute-force attack terutama dalam hal waktu.

Kita berikan contoh. Terdapat sebuah website bernama **redacted.com,** kemudian secara umum kita langsung mencoba dictionary attack berdasarkan nama yang umum sehingga prosesnya adalah sebagai berikut.

URL (dictionary attack)	**Hasil Percobaan**
http://redacted.com/admin	200 OK
http://redacted.com/login	404 Not Found
http://redacted.com/admin.php	404 Not Found
http://redacted.com/public_html.zip	200 OK [Potensial file backup]
http://redacted.com/config.php	404 Not Found

Berdasarkan hasil testing di atas, tidak selamanya wordlists kita berhasil. Mungkin dari ribuah wordlists hanya beberapa saja yang bisa temukan. Maka dari itu semakin baik wordlists anda, maka akan semakin potensial hal unik yang bisa anda temukan.

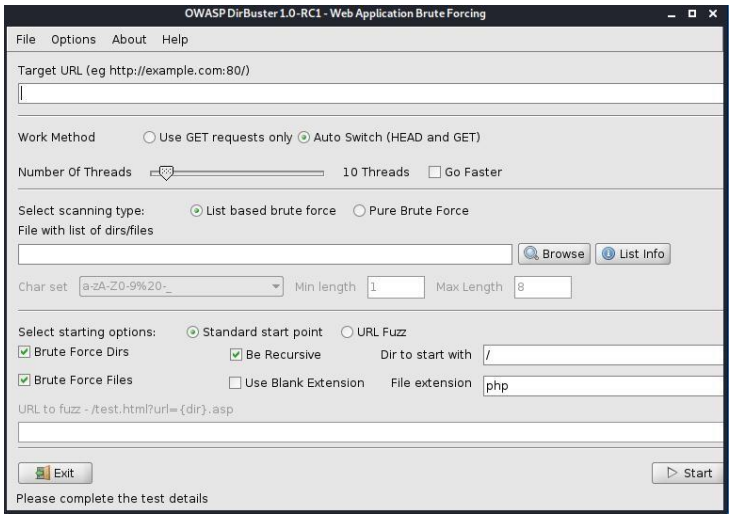
Cukup sulit jika kita melakukan dictionary attack secara manual, anda yang mungkin punya 1 juta wordlist pasti akan kelelahan jika mengetikkan secara manual

via browser. Maka dari itu diperlukan sebuah tool untuk melakukan otomatisasi dictionary attack.

Terdapat banyak tool untuk melakukan dictionary attack, yang paling umum adalah OWASP Dirbuster, tool ini pun sudah terinstall pada Kali Linux. Sedangkan jika teman-teman ingin mencoba yang lain berikut daftar tool yang saya ketahui :

- Ffuf (https://github.com/ffuf/ffuf)
- Gobuster (https://github.com/OJ/gobuster)
- Dirsearch (https://github.com/maurosoria/dirsearch)

Untuk praktek dalam modul ini, kita akan menggunakan Dirbuster. Dirbuster adalah tool berbasis Java yang dikembangkan oleh OWASP (The Open Web Application Security Project), tool ini sudah terinstall pada Kali Linux. Jika anda tidak menggunakan Kali Linux dan ingin menggunakan dirbuster, maka bisa mendownloadnya di https://owasp.org/projects.



H. Mencari Endpoint

Endpoint adalah URL untuk setiap layanan yang terdapat pada website. Contohnya **http://target.com/news.php**

http://target.com/user.php?id=1 http://target.com/api/view/user/1

Dalam melakukan pentest website, sangat penting bagi kita untuk mempelajari setiap fitur yang terdapat pada website,kita harus benar-benar mengenal lebih dalam tentang website tersebut agar nantinya bisa membantu dalam proses mencari celah keamanan. Fitur-fitur ini biasanya menggunakan URL yang berbeda. Disinilah tugas anda untuk mencatat semua endpoint dan pelajari satu-persatu tentang fungsi dari endpoint tersebut.

Pertanyaannya adalah, bagaimana cara mengumpulkan endpoint pada website? Terdapat dua cara, yaitu dengan menggunakan cara manual atau dengan menggunakan tools. Jika menggunakan cara manual, kita harus mengunjungi setiap URL yang terdapat pada website, kemudian kita catat satu-persatu dan tuliskan fungsinya apa. Sedangkan jika menggunakan tools, maka tools tersebut akan melakukan crawling dan mengumpulkan URL secara otomatis.

Yang mana yang lebih baik? Menggunakan cara manual atau tools? Sebenarnya dua-duanya sangat efektif, terkadang dengan menggunakan tools ada saja URL yang tidak ditemukan namun ketika kita menggunakan cara manual maka URL tersebut ditemukan. Jika teman-teman ingin menggunakan tools, dapat menggunakan **Hakrawler**, tools berbasis Golang yang dikembangkan oleh seseorang bernama hakluke.



Tools ini akan mengumpulkan semua endpoint beserta parsing URL dari sitemap dan file robots.txt. Kita juga bisa mengatur level kedalaman crawling.

https://github.com/hakluke/hakrawler

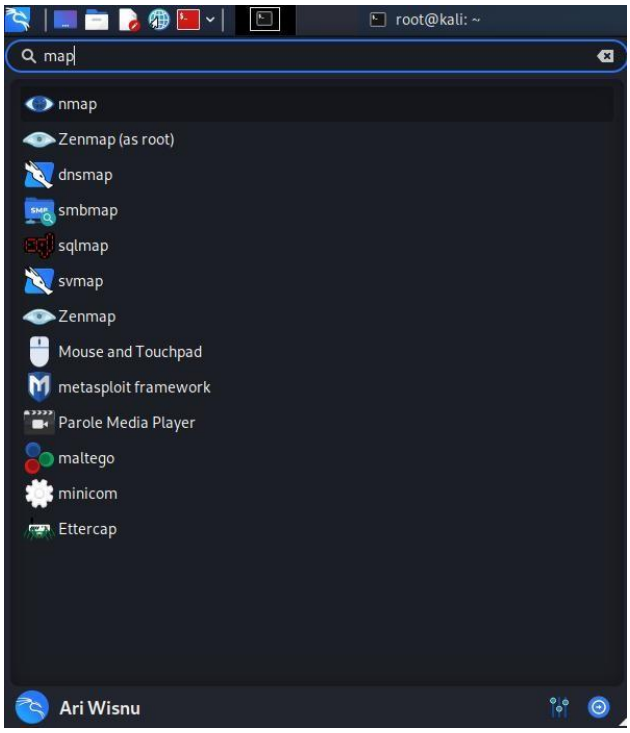
I. NMAP dan ZenMAP

NMAP dan ZenMAP merupakan peralatan yang sangat berguna untuk tahap *scanning* dari *ethical hacking* di OS **Linux**. Pada dasarnya kedua aplikasi ini adalah peralatan yang sama, yang membedakan yaitu, NMAP berbasis pada C*ommand-Line Interface (CLI)* yang bisa digunakan langsung di *Terminal*, sementara ZenMAP adalah NMAP yang memiliki *Graphical User Interface (GUI)*.

Peralatan ini sangat berguna untuk penjelajahan maupun audit keamanan pada suatu jaringan. NMAP menggunakan paket IP dengan cara yang berbeda dari biasanya untuk menentukan *host*, *services*, sistem operasi, bahkan *firewall* apa saja yang ada pada sebuah jaringan.

Cara menggunakannya yaitu:

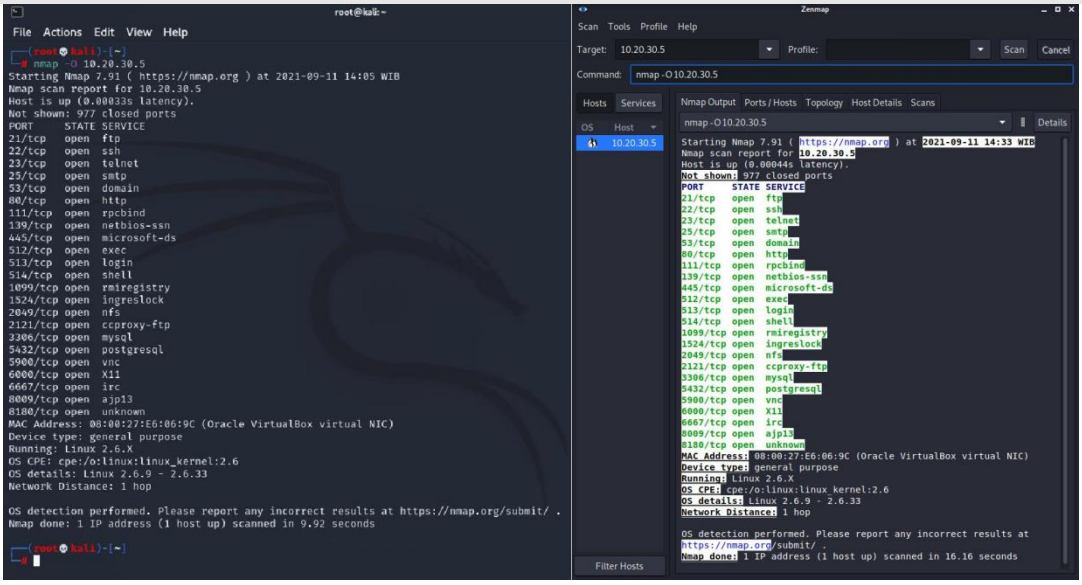
1. Buka aplikasi NMAP atau ZenMAP dengan cara klik Application => Information Gathering. Bisa juga dengan langsung mengetikkan “Map” pada bagian pencarian.



2. Selanjutnya coba untuk mendeteksi sistem operasi dari host lain yang berada pada jaringan dengan aplikasi ini. Berdasarkan pada daftar perintah yang ada pada NMAP (untuk melihat daftar perintah: “nmap -help”) parameter yang digunakan untuk melihat

sistem operasi yang digunakan target host adalah "-O". Maka *command* yang digunakan yaitu:

```
nmap -O <IP target host>
```

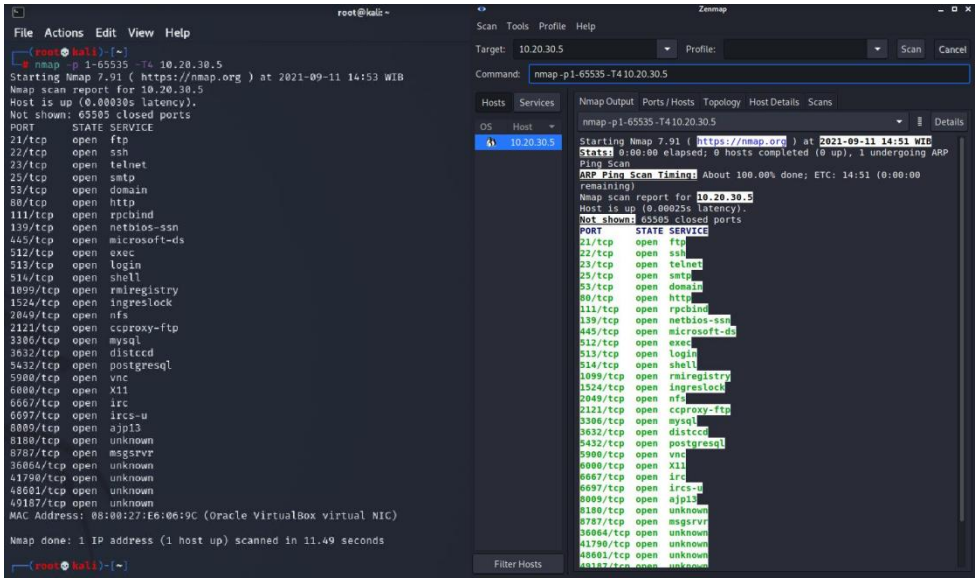


Output data yang dihasilkan dari perintah diatas pada NMAP dan ZenMAP kurang lebih akan sama, tapi untuk orang awam mungkin tampilan dari ZenMAP akan lebih *user-friendly*. Hasil diatas menunjukan berbagai macam informasi seperti, *Port* yang terbuka lengkap dengan *service*nya, *Mac Address*, bahkan sistem operasi yang digunakan oleh target host.

3. Selanjutnya, untuk melihat semua 65535 Port TCP yang terbuka pada target host dapat dilakukan dengan perintah:

```
nmap -p 1-65535 -T4 <IP target host>
```

Parameter "-p" pada perintah diatas menandakan bahwa nmap harus melakukan scanning pada semua 65535 Port TCP yang ada untuk mengetahui apakah port tersebut terbuka atau tidak dan service apa yang menggunakan port tersebut. Parameter "-T4" adalah kecepatan scanning yang dilakukan oleh NMAP.

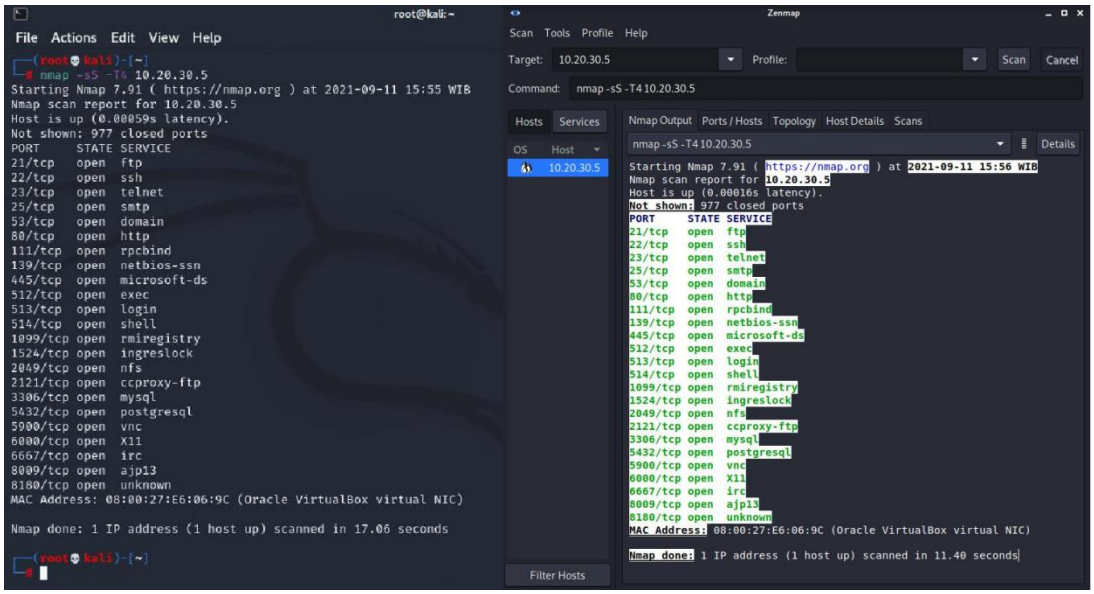


J. Stealth Scan

Stealth Scan atau biasa dikenal juga dengan pemindaian setengah terbuka (*half-open scan*). Metode ini mengirimkan paket SYN ke target host, jika frame SYN/ACK diterima kembali, diasumsikan Port tersebut dalam keadaan terbuka. Jika yang diterima adalah frame RST, maka diasumsikan Port dalam keadaan tidak aktif atau ditutup. Untuk menggunakan metode Stealth Scan parameter yang digunakan pada NMAP yaitu "-sS", perintah lengkapnya akan terlihat seperti ini:

```
nmap -sS -T4 <IP target host>
```

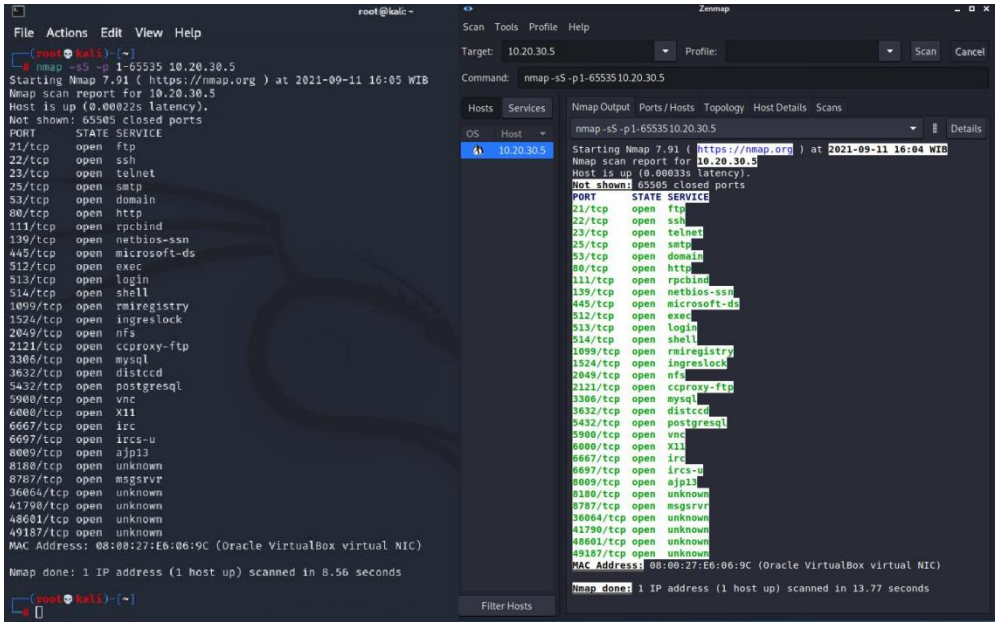
Maka hasilnya akan seperti ini:



Untuk melakukan pemindaian pada semua port yang ada, perintahnya akan menjadi:

```
nmap -sS -p 1-65535 <IP target host>
```

Hasil yang muncul seperti ini:



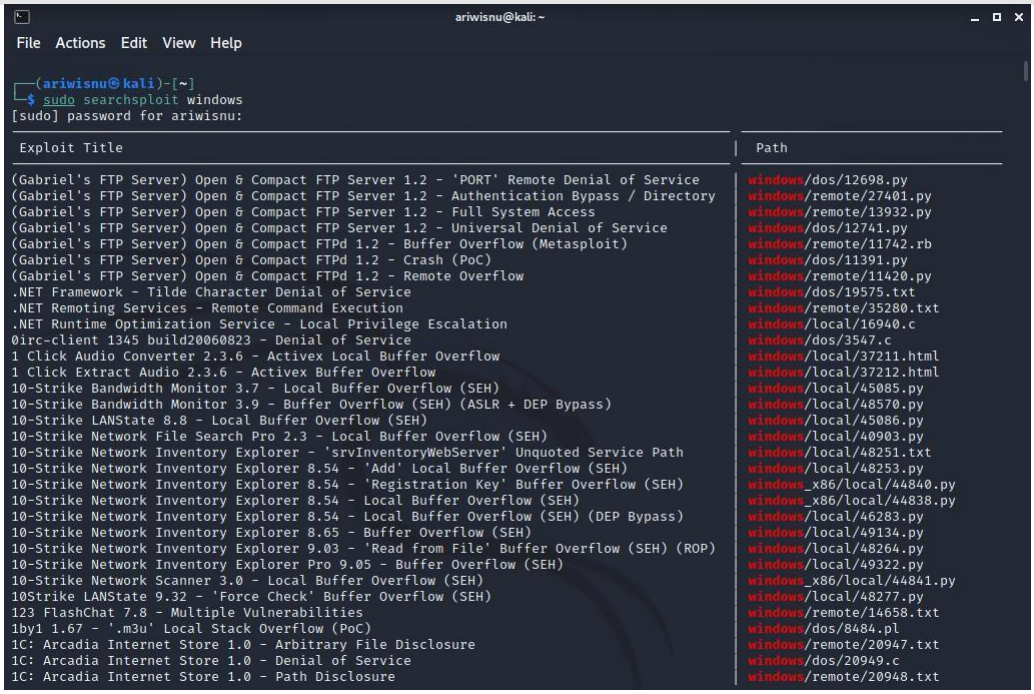
K. Searchsploit

Alat ini membantu pengguna Linux untuk langsung mencari dengan baris perintah (*command line*) dari arsip database exploit. Untuk membuka alat ini, pergi ke Applications => 08-Exploitation Tools => searchsploit, seperti yang terlihat di bawah ini:



Untuk mencobanya, ketikkan perintah berikut ini pada terminal.

```
searchsploit <exploit index name>
```



L. DNS Tools

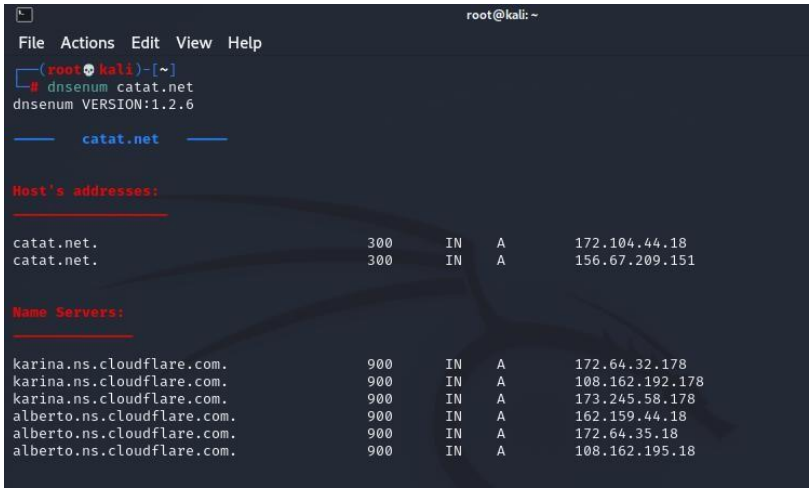
Pada dasarnya, alat ini dapat membantu menyelesaikan permasalahan transfer zona maupun IP domain.

a) dnsenum.pl

Alat yang pertama yaitu dnsenum.pl yang merupakan PERL script yang dapat membantu untuk mendapatkan records MX, A, dan lain-lain yang terhubung pada sebuah domain. Untuk menggunakan, cukup dengan membuka terminal, kemudian mengetikkan perintah berikut:

```
dnsenum <nama domain>
```

Maka hasilnya kurang lebih seperti ini:

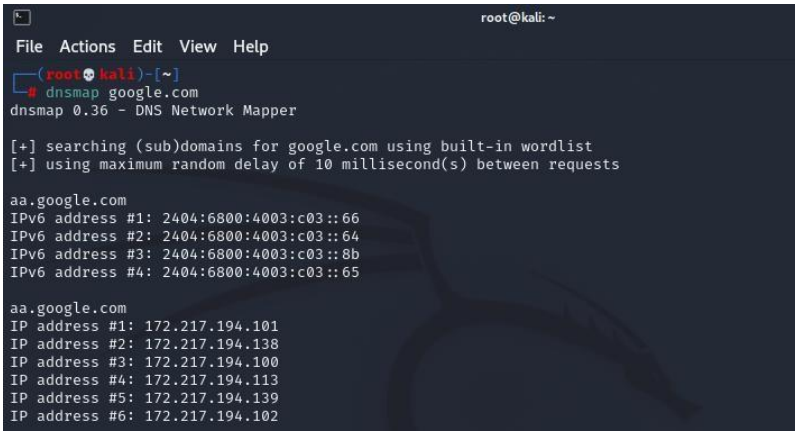


b) dnsmap

Alat selanjutnya yaitu DNSMAP. Alat ini dapat membantu mencari nomor telepon, kontak, dan subdomain lain yang terhubung ke sebuah domain. Cara menggunakannya kurang lebih sama seperti diatas, yaitu dengan cara membuka terminal dan mengetikkan perintah:

```
dnsmap <nama domain>
```

Hasilnya akan seperti ini:



c) dnstracer

Alat ketiga adalah dns tracer, yang menentukan dari mana *Domain Name Server* (DNS) mendapatkan informasinya untuk *hostname* yang diberikan. Cara menggunakan alat ini juga masih sama seperti alat diatas, dengan membuka terminal kemudian mengetikkan perintah berikut:

```
dnstracer <nama domain>
```

Hasilnya:

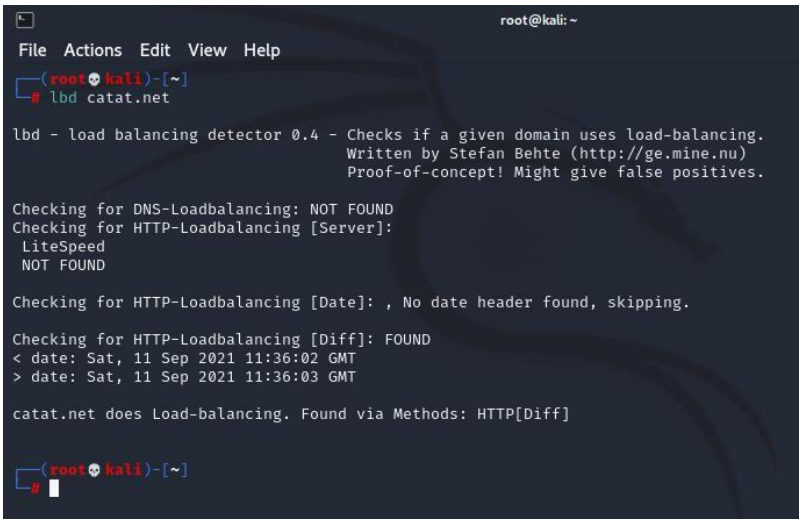


M. LBD Tools

LBD (*Load Balancing Detector*) merupakan alat yang sangat menarik karena alat ini mendeteksi apakah domain yang dimasukkan menggunakan DNS dan/atau HTTP loadbalancing. Ini sangat penting, karena jika terdapat 2 buah server, maka salah satunya bisa saja tidak terperbaharui dan dapat diexploit. Untuk menggunakan alat ini cukup dengan membuka terminal kemudian memasukkan perintah berikut:

```
lbd <nama domain>
```

Hasilnya akan seperti ini:



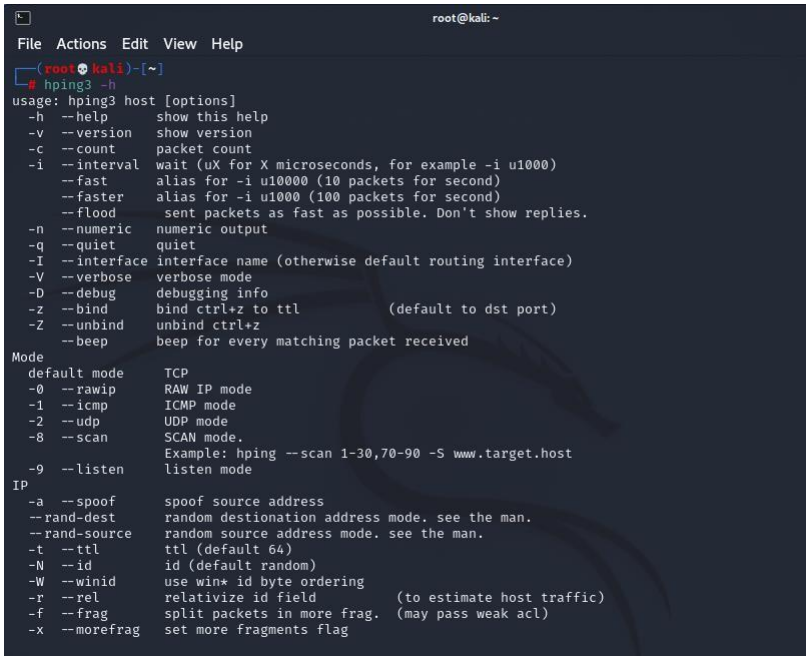
N. Hping3

Hping3 hampir sama seperti alat ping lainnya tetapi lebih kompleks lagi, karena dapat melakukan bypass terhadap filter firewall dan menggunakan TCP, UDP, ICMP, dan RAW-IP Protocols. Alat ini juga memiliki traceroute mode dan kemampuan untuk mengirim berkas antar channel yang dilindungi.

Untuk menggunakannya dapat dengan cara membuka terminal kemudian masukkan perintah:

```
hping3 -h
```

Perintah diatas akan menampilkan kumpulan parameter yang dapat digunakan pada alat ini.



Sehingga untuk menggunakannya kurang lebih perintahnya menjadi seperti ini:

```
hping3 <nama domain> <parameter>
```

Hasilnya akan seperti ini:



Tools di atas hanya beberapa contoh saja, Anda harus eksplor cara dan _tools_ lain untuk mengumpulkan informasi.

Referensi Utama

- The Penetration Testing Execution Standard (PTES), bagian Intelligence Gathering.
- OWASP Web Security Testing Guide (WSTG), Information Gathering.
- Dokumen RoE dan dokumen perencanaan pengujian yang disusun pada pertemuan sebelumnya.
- Dokumentasi resmi tools yang digunakan pada praktikum: subfinder, httpx, WhatWeb, Katana, dan sumber reconnaissance publik yang relevan.